

AWS Centralized Inspection Architecture Blueprint

ARCHITECTURAL BLUEPRINT & DESIGNING FOR PRINCIPAL CLOUD SECURITY ENGINEERS

Document Type: Technical Architecture Blueprint | **Target Role:** Principal Cloud Security Engineer | **Framework Level:** Advanced Enterprise Scale

At a Principal Cloud Security Engineer level, designing cloud architectures shifts away from basic isolated service setups toward building resilient, automated security controls at scale. This blueprint details an enterprise-ready, highly available, and scalable **Centralized Inspection Architecture** using **AWS Transit Gateway (TGW)** and **AWS Network Firewall (ANFW)**.

This pattern implements an **Asymmetric Routing with Separate Appliance Subnets** architecture model. This specific model isolates workloads and avoids the complex routing issues common to multi-zone third-party virtual setups.

1. Architectural Topology Overview

The central design tenet of this blueprint is the consolidation of all organization-wide network ingress and egress points into a specialized, tightly governed network account hub. Network communication paths are split structurally into three major operational patterns:

- **North-South Inbound:** External web traffic entering the organization toward internal business applications.
- **North-South Outbound:** Internal secure applications executing API calls out to vendor systems or external software mirrors.
- **East-West Traffic:** Communication paths moving laterally across spoke boundaries, such as an analytical cluster in a Production VPC fetching records from a database residing inside a shared Data Lake VPC.

Core Architecture Components

- **AWS Transit Gateway (TGW):** Acts as the regional cloud router operating natively at Layer 3. It utilizes separated route-table attachments to implement secure segment partitioning and traffic redirection.
- **Inspection VPC:** A specialized infrastructure VPC spanned systematically across multiple parallel Availability Zones (AZs) that runs security scanning engines exclusively.
- **AWS Network Firewall (ANFW):** A managed, elastic, stateful Layer 3–7 firewall system that performs line-rate Deep Packet Inspection (DPI) and intrusion prevention/detection signatures (IPS/IDS).

2. Structural Subnet Layout (Inspection VPC)

To preserve network resilience and guarantee seamless traffic handling, the Inspection VPC must match the Availability Zone layout used across your workload spokes. Each targeted zone requires complete physical separation of subnets to function cleanly:

```
Inspection VPC (CIDR: 10.100.0.0/16) |— us-east-1a (Availability Zone A) | |— TGW Subnet (Private) --> 10.100.1.0/24 [Host for TGW Attachment Endpoints] | |— Firewall Subnet (Private) --> 10.100.2.0/24 [Host for ANFW Virtual Core Endpoints] | |— NAT Gateway Subnet (Public)--> 10.100.3.0/24 [Host for Public Nat GW & Ingress Elements] |— us-east-1b (Availability Zone B) |— TGW Subnet (Private) --> 10.100.11.0/24 [Host for TGW Attachment Endpoints] |— Firewall Subnet (Private) --> 10.100.12.0/24 [Host for ANFW Virtual Core Endpoints] |— NAT Gateway Subnet (Public)--> 10.100.13.0/24 [Host for Public Nat GW & Ingress Elements]
```

CRITICAL PRINCIPAL ARCHITECTURE RULE

Do not co-locate Transit Gateway endpoints, NAT Gateways, and AWS Network Firewall endpoints together within the same subnet. AWS Network Firewall expects traffic to cross structural subnet boundaries explicitly to trigger its packet evaluation loops.

3. The Core Routing Mechanics (The "Choke Points")

The security value of this design depends on precise routing configuration across your **Transit Gateway Route Tables** and your **VPC Subnet Route Tables**. Together, these rules form an inescapable choke point that prevents traffic from bypassing your inspection endpoints.

A. Transit Gateway Route Tables (Enterprise Segmentation)

To avoid default routing loops, you must maintain at least two distinct route validation tables at the TGW layer:

Route Table Context	Destination CIDR	Target Execution Target	Operational Impact
Spoke VPC TGW Route Table (Associated to App/DB Spokes)	<i>0.0.0.0/0</i> <i>10.0.0.0/8</i>	Inspection VPC Attachment Target	Prevents direct communication between spokes or out to the internet. All packets are forced down to the inspection layer.
Inspection VPC TGW Route Table (Associated to Inspection VPC)	<i>10.1.0.0/16</i> (Spoke A) <i>10.2.0.0/16</i> (Spoke B)	Target Spoke VPC Specific Attachments	Once packets return verified from the firewall, this table guides traffic to its final internal spoke destination.

B. Inspection VPC Subnet Route Tables (Intra-VPC Routing)

Each subnet layer inside the Inspection VPC manages a specific step in the packet lifecycle through these directional routing entries:

1. TGW Subnet Route Table (Configured per AZ)

- Default Route (*0.0.0.0/0*) → Routes to local **AWS Network Firewall Endpoint** (*vpce-xxxxxx*) in the matching zone.
- Enterprise Summary Route (*10.0.0.0/8*) → Routes directly to the local **AWS Network Firewall Endpoint**.

2. Firewall Subnet Route Table (Configured per AZ)

- Default Route (*0.0.0.0/0*) → Routes to the local **NAT Gateway** instance (for external outbound processing).
- Enterprise Summary Route (*10.0.0.0/8*) → Routes back into the ****Transit Gateway Router Attachment****.

3. Public NAT Gateway Subnet Route Table (Configured per AZ)

- Default Route (*0.0.0.0/0*) → Routes to the local **VPC Internet Gateway (IGW)**.
- Enterprise Return Route (*10.0.0.0/8*) → Routes traffic back through the local ****AWS Network Firewall Endpoint****.

4. Operationalizing AWS Network Firewall Rulesets

As a Principal Engineer, your rules should use a two-tier approach, combining high-speed stateless filtering with deep, context-aware stateful evaluation.

A. Stateless Rules (Layer 3/4 Layer - Network Rejection)

Stateless rules inspect packets individually. Use them to instantly drop plain-text anomalies or block untrusted structural access patterns before they reach your stateful analysis engine.

- **Insecure Ingress Drop Rule:** Instantly drop plain-text inbound delivery attempts on unencrypted management channels like port 21 (FTP), port 23 (Telnet), or port 3389 (RDP) directly at the boundary.
- **Forward Rule Configuration:** Forward valid corporate infrastructure ranges (*10.0.0.0/8*) to the stateful engine for deeper threat verification.

B. Stateful Rules (Layer 5/7 Layer - Deep Traffic Verification)

Stateful rules review whole data streams within context. You should leverage industry-standard **Suricata compatible IPS rule sets** to implement strict, domain-specific egress rules across your applications:

```
# Restrict HTTP/TLS outbound paths to approved service vendor domains only
pass http $HOME_NET any -> $EXTERNAL_NET any (http.host; dotest;
pcpre:"/*.*\.amazonaws\.com$/*"; sid:1000001; rev:1;)
pass tls $HOME_NET any -> $EXTERNAL_NET any (tls.sni; dotest; pcpre:"/*.*\.github\.com$/*";
sid:1000002; rev:1;)
drop ip $HOME_NET any -> $EXTERNAL_NET any (msg:"CRITICAL WARNING: Unauthorized Data
Egress Attempt Blocked"; sid:9999999; rev:1;)
```

5. Prevented Attack Chain Scenario: Ransomware & Data Exfiltration

To understand the value of this architecture, trace how it completely neutralizes a multi-step, production-scale attack vector:

1. **The Attack Vector:** An internet-facing application container within a development spoke is compromised using a remote code execution (RCE) flaw.
2. **The Goal:** The threat actor attempts to execute a curl script to download a malicious payload from an unapproved control domain (*bad-actors-c2.com*), scan internal subnets for databases, and exfiltrate matching tables.
3. **How the Architecture Responded:**
 - The compromised container attempts an outbound request to *bad-actors-c2.com*.
 - The local spoke's subnet routing forces the traffic into the central Transit Gateway.
 - The TGW Route Table checks the destination and forces the packets into the Inspection VPC's TGW subnet attachment.
 - The local TGW subnet route redirects the traffic through the **AWS Network Firewall Endpoint**.
 - The stateful inspection engine reads the TLS Client Hello SNI string. It identifies that *bad-actors-c2.com* is missing from your corporate whitelist.
 - The firewall **drops the packet inline**, writes an alert log instantly to CloudWatch, and completely kills the attack chain at the reconnaissance stage.

6. Enterprise-Scale Remediation & IaC Deployment

Do not build this setup manually using the AWS Console. To ensure consistency across environments and prevent configuration drift, declare everything as **Infrastructure as Code (Terraform)**.

When defining this setup, make sure to enable **Appliance Mode** on the Transit Gateway VPC attachment. This keeps traffic flows tied to the same Availability Zone throughout their session lifecycle. This setting avoids asymmetric routing errors, ensuring outbound packets and their corresponding return traffic pass through the same firewall endpoint.

AUTOMATED REMEDIATION ENFORCEMENT

Deploy continuous **AWS Config Rules** (such as `vertex-tgw-route-check`) tied to automated AWS Systems Manager documents. If an engineer creates a new spoke VPC and attempts to bypass the inspection network by attaching a direct internet route, the automation engine will instantly catch the deviation, tear down the non-compliant route, and restore traffic through the centralized inspection paths.